Enterprise Host Security Policy

Effective Date:
March 05, 2026

Category:
Security

Scheduled Review:
March 2027

1. Authority

Executive Order 2016-06, Enterprise Information Technology Governance

2. Document Control

This document replaces, in its entirety, the *Enterprise Host Security Policy*, dated January 6, 2025.

3. Purpose

This Information Technology Policy (ITP) establishes the security requirements for Hosts connecting to the Commonwealth network and defines the enterprise controls governing technologies such as Endpoint Detection and Response (EDR) and Data Loss Prevention (DLP).

4. Scope

This policy applies to all offices, departments, boards, commissions, and councils under the Governor's jurisdiction and any other entity connecting to the Commonwealth Network (hereinafter referred to as "agencies").

5. Policy

For definitions found within this document, refer to the *IT Policy Glossary*.

5.1 Host Security

Agencies shall use all the enterprise-standard Host security tools, as defined in the *Enterprise Host Security Standard*.

Host security tools shall operate in detection/removal or blocking/prevention modes at all times.

Agencies shall utilize the most current, approved versions of these enterprise-standard Host

security tools for real-time scanning, detection/removal, and blocking/prevention capabilities. This applies to all IT Resources.

Agencies shall comply with the IT Resource patching requirements established in the *IT Resource Patching Policy.*

OA/IT utilizes enterprise-level controls and monitoring of these security solutions to protect critical technology assets. All agencies are required to participate in the enterprise deployment, management, and monitoring of these security solutions.

Devices failing to comply with IT Policies and standards may be denied network access.

OA/IT may, after appropriate escalation and notification procedures have been followed, use enterprise-level authority to update agency devices, if non-compliance is seen as an urgent threat to the security of the Commonwealth network.

5.2 Data Loss Prevention (DLP)

Any DLP technology/solution must comply with the technical specifications and requirements outlined in the following Commonwealth ITP's:

- *Data Classification Policy*
- *Encryption Policy*

Note: This ITP establishes the enterprise baseline minimum requirement for DLP. Agencies subject to additional regulatory standards (e.g., CJIS, IRS Pub 1075, PCI DSS, HIPAA) shall implement stricter controls as required.

5.3 Cyber Forensics

OA/OIT shall be responsible for all cyber forensics.

Agencies shall ensure the enterprise forensics solution as detailed in the Enterprise Host Security Standard is installed on all IT Resources.

Agencies shall ensure that the required traffic path is open for communication with the enterprise forensics solution.

5.4 Incident Reporting

The Agency ISO or designee shall conduct investigations into incidents involving potential or confirmed compromises of Commonwealth Data. Any confirmed or suspected compromises shall be reported in accordance with the *IT Security Incident Reporting Policy*.

6. Contact

Questions or comments may be directed via email to OA, IT Policy.

7. Exception from Policy

In the event an agency chooses to seek an exception from this policy, a request for a policy exception shall be submitted via the IT policy exception process. Refer to *IT Policy Governance Policy* for guidance.

8. Revision History

This chart contains a history of this publication's revisions. Redline documents outline the revisions and are available to Commonwealth users only during the drafting process.

Version	Date	Purpose of Revision
Original	01/06/2025	Base Document
Revision	03/05/2026	Removed requirements that are no longer applicable. Updated roles and responsibilities and relocated to the Enterprise Host Security Standards Document Added a brief section on cyber forensics Updated references Misc. clarifications and grammatical updates